MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 063 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

ARGUMENT · IDENTIFICATION AND AUTHENTICATION

Your Password Policy Answers to Two NIST Documents That Disagree

NIST 800-171 Rev 2 still asks for password complexity under 3.5.7, while SP 800-63B-4 forbids composition rules. How one policy satisfies both.

BY MAXINE

READING TIME · 5 MIN

PASSWORDS · NIST-800-171 · NIST-800-63B · IDENTIFICATION-AUTHENTICATION · CMMC

A small defense contractor writing its password policy this year is answering to two NIST documents that no longer agree. NIST SP 800-171 Rev 2, the revision DFARS 252.204-7012 still binds and SPRS still scores, asks in requirement 3.5.7 that the organization "enforce a minimum password complexity and change of characters when new passwords are created." NIST SP 800-63B-4, the authentication guideline NIST finalized in July 2025, tells verifiers they "SHALL NOT impose other composition rules (e.g., requiring mixtures of different character types)." The first is the contract. The second is the government's current reading of what makes a password hard to guess. This column argues that a shop does not have to choose between them, provided it writes its definitions with care, because Rev 2 asks the organization to define the rules before it asks anyone to enforce them.

The four requirements in play are small on the scoresheet, with one exception. Under the DoD Assessment Methodology, 3.5.7 (complexity and change of characters), 3.5.8 (no reuse for a set number of generations) and 3.5.9 (temporary passwords replaced at once) are worth 1 point each. Requirement 3.5.10, which asks that passwords be stored and transmitted only in cryptographically protected form, is worth 5. The difference matters beyond the arithmetic. The three 1-point requirements are not among the six that 32 CFR 170.21 bars from a Level 2 POA&M, so a gap in any of them can be carried and closed later. Requirement 3.5.10 exceeds the 1-point ceiling and cannot.

FIELD COPY
ISSUE Nº 063
PASSWORDS

8

SPRS POINTS ACROSS 3.5.7 TO 3.5.10, AND 5 OF THEM SIT ON 3.5.10, CRYPTOGRAPHIC PROTECTION

15

CHARACTERS, THE SP 800-63B-4 MINIMUM FOR A PASSWORD USED AS THE ONLY FACTOR, OR 8 WHEN IT IS ONE FACTOR OF SEVERAL

0

MAXIMUM PASSWORD AGES NAMED IN THE REQUIREMENT TEXT OR THE 800-171A OBJECTIVES OF 3.5.7 TO 3.5.10

The contract lets you define the rules

Read the NIST SP 800-171A objectives for 3.5.7 and the conflict narrows. Two of its four objectives ask whether something is defined: password complexity requirements (3.5.7[a]) and password change of character requirements (3.5.7[b]). The other two ask whether the requirements, as defined, are enforced when new passwords are created. The requirement fixes no character classes, no minimum length and no number of changed characters. Those are the organization's to state, and an undefined requirement fails 3.5.7[a] before anyone opens a configuration screen.

That leaves room for a policy written to 800-63B. A reasonable reading, and it is a reading rather than settled assessment practice, is that a complexity requirement defined as a minimum length plus a check against a list of common and breached passwords is still a complexity requirement. SP 800-63B-4 sets that length at 15 characters for a password used as the only factor and 8 for one used only inside multi-factor authentication, asks verifiers to accept at least 64, and requires the whole prospective password to be compared against a blocklist of commonly used, expected or compromised values. A policy that states those numbers, with a configuration that enforces them, hands an assessor a defined requirement and the evidence of its enforcement, which is what the objectives test. A shop uneasy with that reading can keep one modest character rule and accept the small cost in usability. What it should not do is leave complexity unwritten.

Change of characters is the harder half, because 800-63B has no counterpart to it. The requirement asks that a new password differ from the old one by some number of characters. The defensible course is to define that number, keep it modest, and let the blocklist and the reuse rule carry the real weight. Requirement 3.5.8 asks only that a number of generations be specified (3.5.8[a]) and that reuse inside it be prohibited (3.5.8[b]). It says nothing about how often a password must change.

Neither 3.5.7 nor its three neighbors names a maximum password age. A ninety-day expiry, where a shop enforces one, comes from habit, not from these requirements.

Where the two documents already agree

Forced rotation is the clearest case. SP 800-63B-4 says verifiers "SHALL NOT require subscribers to change passwords periodically," and that they must force a change when there is evidence of compromise. The requirement text and the 800-171A objectives for 3.5.7 through 3.5.10 contain no maximum age at all. A shop that drops a calendar-driven expiry gives up nothing on the scoresheet, provided its policy states what does trigger a forced change, and evidence of compromise is the trigger both documents can live with.

Requirement 3.5.9 is the help-desk reset. Its single objective asks that a temporary password used for logon be replaced immediately by a permanent one, and Rev 3 folds the same idea into 03.05.07 as selecting a new password on first use after account recovery. The evidence is mundane: the directory setting that forces a change at next logon, which the examine list reaches through system configuration settings and password configurations.

Requirement 3.5.10 is where the points are, and where the documents agree most. Its two objectives ask that passwords be cryptographically protected in storage (3.5.10[a]) and in transit (3.5.10[b]). SP 800-63B-4 is more specific: passwords salted and hashed with a suitable password hashing scheme, a salt of at least 32 bits, and approved encryption over an authenticated protected channel whenever a password is requested. The exposures worth checking first sit at the edges of an enclave rather than at its main sign-in: a legacy protocol that still accepts weaker authentication, or a service account password kept in a script or a spreadsheet. MacZine's field report on hardening Windows Server 2025 found the NTLM compatibility level short of the STIG on exactly this requirement. A password in a plaintext file fails 3.5.10[a] whatever the policy says, and at 5 points with no POA&M available, it is the most expensive line in the family.

The policy that satisfies both documents fits on one page of the system security plan. It states the minimum length and the blocklist as the complexity requirement, the change-of-character number and the reuse generations, a forced change on evidence of compromise and on first use of a temporary password, and the hashing and protocol settings that carry 3.5.10. It pairs those length rules with multi-factor authentication where 3.5.3 requires it, which is also the condition under which 800-63B accepts the 8-character floor. Rev 3 has already moved toward 800-63B, and when DoD's baseline eventually follows, a policy written this way will need the fewest edits. Until then the contract scores Rev 2, and what it scores is plain: a rule written down, and a setting that enforces it. A program that wants the rest of its identification and authentication family read the same way can start at /readiness. ◆

◆ WHERE REV 3 ALREADY LANDED

NIST SP 800-171 Rev 3 rewrote this ground as requirement 03.05.07, Password Management, which adds a list of commonly used, expected, or compromised passwords checked at every change. Its guidance says enforced composition rules provide marginal security benefits while decreasing usability. Rev 3 does not bind DoD contracts, because class deviation 2024-O0013 R1 keeps DFARS 252.204-7012 pinned to Rev 2.